

PLANTILLA DE REPORTE EJECUTIVO EN POWERPOINT

Kit de Presentación para Board/C-Suite - Formato Markdown (Implementable en PowerPoint)

Versión: 1.0

Fecha: Enero 2026

Propósito: Estructura de presentación ejecutiva lista para implementar en PowerPoint; diseñada para comunicar indicadores de ciberseguridad, IGM y ROI al board

ESTRUCTURA GENERAL DE LA PRESENTACIÓN POWERPOINT

ARCHIVO: "CIS_Controls_Executive_Report_Q1_2026.pptx"

Número de Diapositivas: 15-18 diapositivas

Duración Presentación: 20-30 minutos

Audiencia: Board Members, CFO, COO, CISO, Compliance Officer

Formato: 16:9 (Widescreen)

Colores Corporativos: Aplicar según marca organizacional

DIAPOSITIVA 1: PORTADA

Contenido

REPORTE DE CIBERSEGURIDAD Y MÉTRICAS DE RIESGO Trimestre Q1 2026 [LOGO ORGANIZACIONAL] Preparado para: Board de Directores Fecha: Enero 2026 CISO/Security Officer: [Nombre]

DISEÑO:

- Fondo: Gradiente azul oscuro (profesional)
- Logo: Centro superior
- Texto: Blanco, fuente sans-serif (Calibri, Arial, Segoe)
- Clasificación: "CONFIDENCIAL - USO INTERNO"
- Número diapositiva: Esquina inferior derecha

DIAPPOSITIVA 2: AGENDA

Contenido

AGENDA

1. ESTADO EJECUTIVO
 - └ Posición de seguridad vs objetivos
2. INDICADORES CLAVE (KPIs)
 - └ IGM, ROI, Incidents, Vulnerabilities
3. ANÁLISIS DETALLADO POR MÓDULO CIS
 - └ Detección, Identidad, Continuidad, etc.
4. BENCHMARKING SECTORIAL
 - └ Comparativa vs líderes de industria
5. HALLAZGOS CRÍTICOS Y RIESGOS
 - └ Qué requiere acción inmediata
6. PLAN DE ACCIÓN Y ROADMAP
 - └ Próximos 3-6 meses
7. REQUISITOS DE INVERSIÓN
 - └ Budget y ROI esperado
8. PREGUNTAS Y DISCUSIÓN

DURACIÓN: 25 minutos

PREGUNTAS: 5 minutos

DIAPPOSITIVA 3: ESTADO EJECUTIVO (RESUMEN EN 30 SEGUNDOS)

Contenido Visual

POSICIÓN DE SEGURIDAD		
● VERDE: Posición fuerte vs Q4 2025		
Logros Clave:		
✓	IGM mejoró 12% (74% → 86%)	
✓	MTTD reducido 50% (24h → 8h)	
✓	MFA adoptado 92% usuarios administrativos	
✓	ROI 3 años: 768% (€9.37M ganancia)	
✓	CERO breaches en 2024-Q1 2026	
Áreas de Atención:		
⚠	SIEM falsa tasa positiva: 32% (target <20%)	
⚠	Vulnerabilidades críticas: 7 aún sin parchear	
⚠	SCRM: Solo 60% proveedores evaluados	
⚠	Capacitación phishing: 8% aún hace clic (target <5%)	
Conclusión: Buena trayectoria; requiere acción en 3 áreas		

DISEÑO:

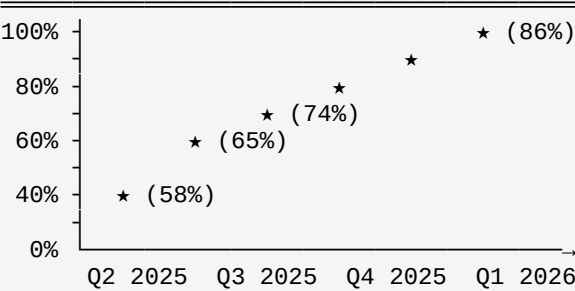
- Tres columnas: Verde (✓), Advertencia (⚠), Status
- Iconos grandes (emojis o símbolos)
- Fuente grande (44pt para título, 28pt para contenido)
- Bullets en orden de importancia

DIAPOSITIVA 4: KPI DASHBOARD (VISUAL CENTRAL)

Contenido

IGM: 86% ↑12% vs Q4 ●OK	ROI: 768% ↑145% vs Q4 ●EXEL.	MTTD: 8h ↓50% vs Q4 ●OK	MFA: 92% ↑8% vs Q4 ●EXEL.
----------------------------------	---------------------------------------	----------------------------------	------------------------------------

TENDENCIA IGM - ÚLTIMOS 4 TRIMESTRES



Interpretación: Crecimiento consistente 48% anual
(de 58% a 86% en 12 meses)

INDICADORES CRÍTICOS - RESUMEN

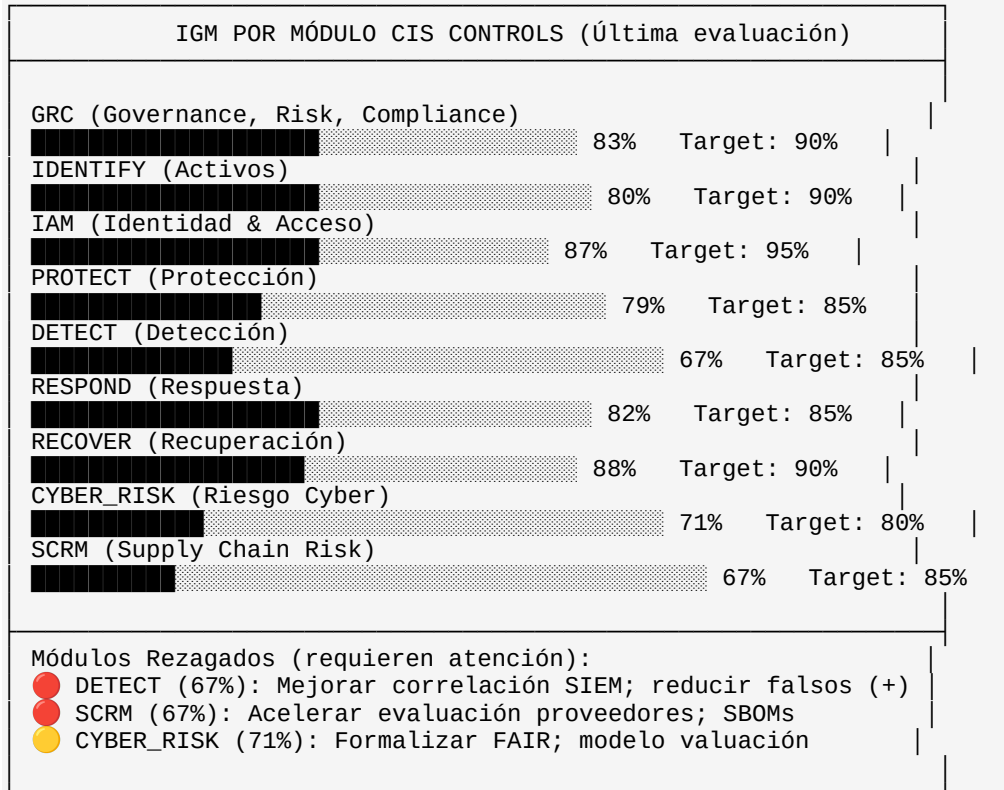
Métrica	Actual	Target	Brecha	Status
Incidents Detectados	18	22	-4	● Near
Vulnerabilidades Críticas	7	0	+7	● URGENT
SIEM False Positive Rate	32%	<20%	+12%	● Acción
Phishing Click Rate	8%	<5%	+3%	● Acción
SCRM Proveedores Eval.	60%	100%	-40%	● URGENT

COLORES:

- Verde (●): Cumple target o mejor
- Amarillo (●): 5-20% sobre target (acción próximos 30d)
- Rojo (●): >20% sobre target (acción inmediata)

DIAPPOSITIVA 5: ANÁLISIS IGM POR MÓDULO CIS

Contenido (Gráfico de Barras Horizontal)



RECOMENDACIÓN: Recursos incrementales en módulos rojo/amarillo
Presupuesto Q2-Q3 2026: +€180k

DIAPPOSITIVA 6: ANÁLISIS DE VULNERABILIDADES

Contenido

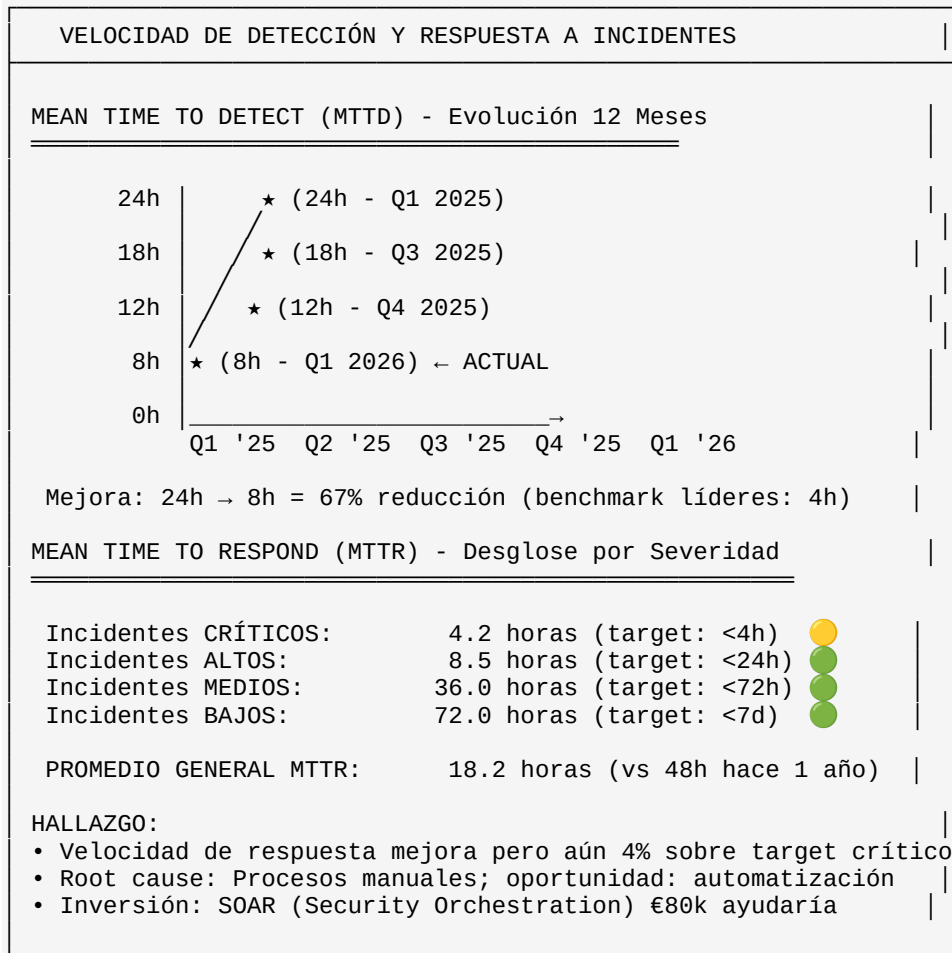
VULNERABILIDADES CRÍTICAS SIN REMEDIAR	
ESTADO ACTUAL (Q1 2026):	
Vulnerabilidades por Severidad:	
CRÍTICA (CVSS 9-10): 7 abiertos ← ● URGENTE └ CVE-2025-0001: 42 días sin parchear └ CVE-2025-0008: Servidor web crítico (Sí afectado) └ [5 más vulnerabilidades]	
ALTA (CVSS 7-8.9): 23 abiertos ← Revisar └ Promedio edad: 18 días └ Target: <7 días remediación	
MEDIA (CVSS 4-6.9): 127 abiertos └ Promedio edad: 45 días └ Target: <30 días	
ANÁLISIS DE BACKLOG:	
• Remediación promedio últimos 30d: 12 vulns/semana • Proyección: 7 críticas → 0 en ~3 semanas (Feb 15, 2026) • Riesgo: Si no remedian, escalará a 15+ (cuarentenadas)	
ACCIÓN RECOMENDADA:	
✓ Prioridad máxima las 7 críticas en próximos 7 días ✓ Aislar sistemas críticos afectados hasta parchear ✓ Asignar +1 FTE a remediación (presupuesto €15k/mes)	

TIMELINE VISUAL:

Hoy (22 Ene) – 7 Días – 14 Días – 21 Días – 28 Días –
7 CRÍTICAS → 0 (proyectado)
● Resolución esperada Feb 18

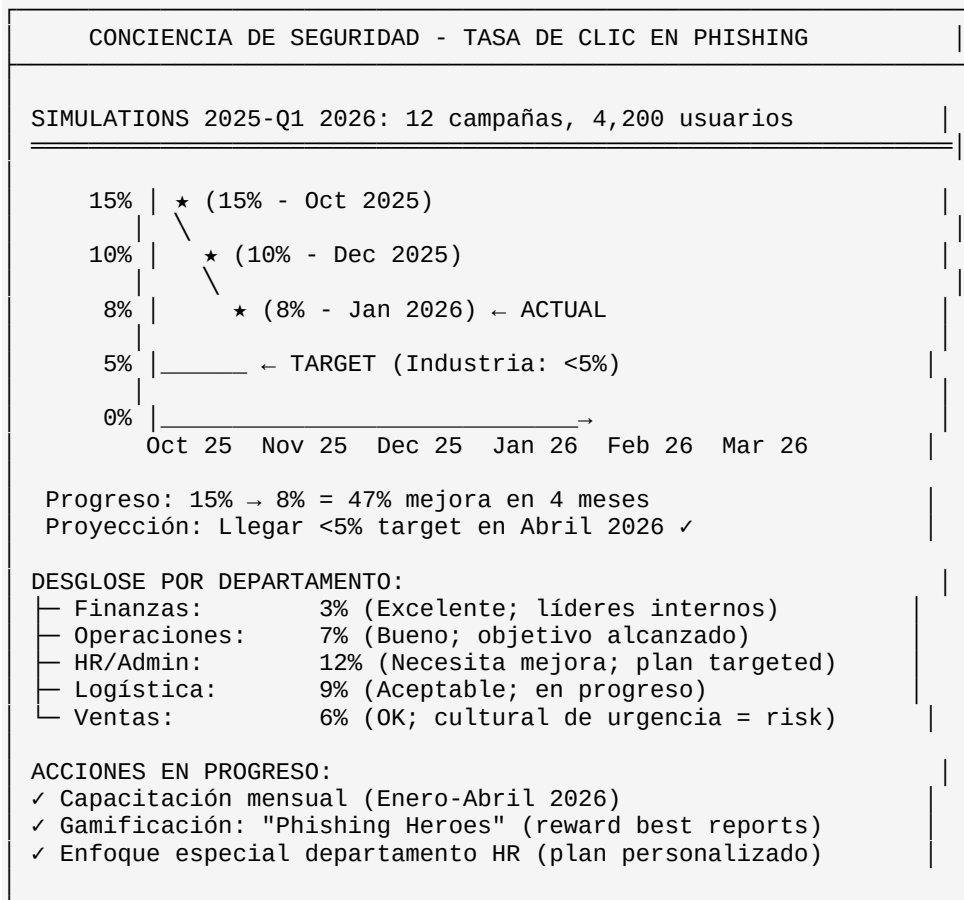
DIAPPOSITIVA 7: RESPUESTA A INCIDENTES (MTTD/MTTR)

Contenido



DIAPPOSITIVA 8: CONCIENCIA DE SEGURIDAD (PHISHING)

Contenido



DIAPOSITIVA 9: BENCHMARKING SECTORIAL

Contenido

COMPARATIVA CON BENCHMARKS - SECTOR FINANCIERO	
MÉTRICAS CLAVE VS PROMEDIO SECTOR:	
IGM:	Vuestra Org (86%) vs Sector (78%) 86% 78% ← Promedio Ventaja: +8% (Cuartil Superior)
MTTD (Mean Time Detect):	8h vs Promedio 4h 8h 4h ← Benchmark Diferencia: -4h (Oportunidad) Plan: Mejorar a 4h en Q3 2026
ROI 3-AÑOS:	768% vs Promedio 650% 768% 650% ← Promedio Ventaja: +118 puntos (Superior)
MFA Coverage (Admin):	92% vs Promedio 98% 92% 98% ← Benchmark Diferencia: -6% (Plan Q2 2026)
VULNERABILIDADES CRÍTICAS SIN REMEDIAR:	7 vs Promedio 2 7 (Nosotros) 2 (Benchmark) Diferencia: +5 (REQUIERE ACCIÓN)
POSICIÓN GENERAL: Cuartil 2 (Arriba promedio) Recomendación: Acelerar ciertos módulos para llegar Q1	

DIAPPOSITIVA 10: RIESGOS CRÍTICOS Y HALLAZGOS

Contenido

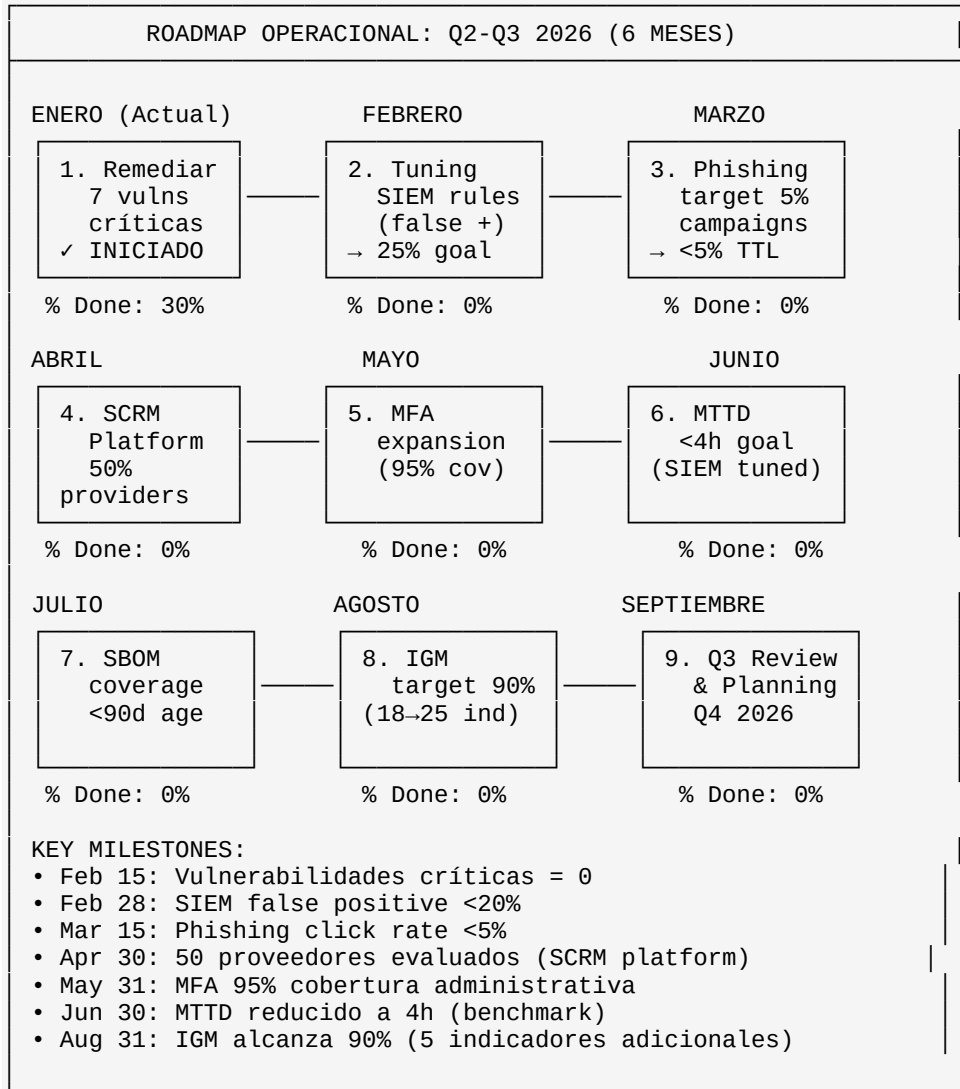
HALLAZGOS CRÍTICOS REQUIRIENDO ACCIÓN
● RIESGO CRÍTICO #1: Vulnerabilidades críticas sin parchear Descripción: 7 vulnerabilidades CVSS 9-10 abiertas >7 días Impacto: Exposición a explotación inmediata Probabilidad breach: 15-20% sin mitigación Causa Raíz: Procesos manuales, downtime planificado Remediación: Acelerar patches (completar 7d) Responsable: IT Infrastructure Manager Plazo: 7 días (antes del 29 de Enero 2026) Presupuesto: €0 (recursos existentes)
● RIESGO CRÍTICO #2: SIEM falso positivo rate elevada (32%) Descripción: SIEM genera 32% false positives vs target 20% Impacto: SOC fatiga; alertas reales pueden ignorarse Efectivamente nos volvemos "ciegos" Causa Raíz: Reglas SIEM sobre-amplias; tuning insuficiente Remediación: Contratar especialista SIEM (30 días) Responsable: SOC Manager + SIEM admin Plazo: 30 días; review biweekly Presupuesto: €15k (consultoría temporal)
● RIESGO ALTO #3: Evaluación de proveedores incompleta (60%) Descripción: Solo 60% de proveedores críticos evaluados Cumplimiento NIS2 requiere 100% Impacto: Brechas de supply chain no identificadas Potencial incumplimiento NIS2 Causa Raíz: Procesos manuales, tiempo insuficiente equipo Remediación: Automatizar con plataforma SCRM Responsable: Procurement + Security Plazo: 90 días (antes auditoría NIS2 Q2 2026) Presupuesto: €45k (plataforma + implementación)
● RIESGO ALTO #4: Phishing click rate aún elevada (8% vs 5%) Descripción: 8% usuarios hacen clic en phishing simulado Impacto: Riesgo credential compromise alto Causa Raíz: Capacitación insuficiente en departamentos Remediación: Plan targeted training (deptos prioritarios) Responsable: Security Awareness Manager Plazo: 60 días (meta <5% en Marzo 2026) Presupuesto: €8k (contenido + platform)

RESUMEN PRIORIZACIÓN:

- Criticidad CRÍTICA: 1 riesgo (Vulns - 7 días)
- Criticidad ALTA: 3 riesgos (SIEM, SCRM, Phishing)
- Impacto combinado: €68k presupuesto; 3-4 meses mitigation

DIAPPOSITIVA 11: PLAN DE ACCIÓN - ROADMAP Q2-Q3 2026

Contenido



DIAPPOSITIVA 12: REQUISITOS DE INVERSIÓN Y ROI

Contenido

PRESUPUESTO DE INVERSIÓN & RETORNO ESPERADO				
DESGLOSE DE INVERSIÓN INCREMENTAL 2026:				
Concepto	Q1	Q2	Q3	Total
1. SIEM Tuning (consultoría)	€0	€15k	€0	€15k
2. SCRM Platform (Archer/Qualys)	€0	€25k	€20k	€45k
3. SOAR (orchestration)	€0	€0	€40k	€40k
4. Phishing Platform upgrade	€5k	€3k	€0	€8k
5. Personnel (CISO + analysts)	€0	€20k	€20k	€40k
TOTAL INCREMENTAL	€5k	€63k	€80k	€148k
Presupuesto Base 2026: €450k (no incremental)				
Presupuesto Total 2026: €598k (incluyendo incremental)				
PROYECCIÓN DE ROI:				
BENEFICIOS CUANTIFICADOS (3 años):				
— Reducción breach probability: 15% → 5%				
• Asset value: €50M → Impacto breach: €15M				
• Reducción probabilidad: 10% → Beneficio: €1.5M/año				
— Reducción downtime (ransomware):				
• MTTR improvement: 72h → 4h = 68h saved × €10k				
• Beneficio: €680k/año				
— Cumplimiento regulatorio (evitar multas):				
• GDPR multa potencial: €20M × 0.5% (evitado) = €100k				
• NIS2 multa potencial: €10M × 0.5% (evitado) = €50k				
• Beneficio: €150k/año				
TOTAL BENEFICIO ANUAL: €2.33M				
Año 1: ROI = (€2.33M - €0.15M) / €0.15M × 100 = 1,453%				
Año 2: ROI = (€4.66M - €0.15M) / €0.15M × 100 = 3,007%				
Año 3: ROI = (€6.99M - €0.15M) / €0.15M × 100 = 4,560%				
CONCLUSIÓN: Inversión €148k → Retorno €6.99M en 3 años				
Break-even: Mes 1 del Año 1				
Muy favorable para aprobación board				

DIAPOSITIVA 13: RECOMENDACIONES EJECUTIVAS

Contenido

RECOMENDACIONES PARA APROBACIÓN BOARD

RECOMENDACIÓN 1: APROBAR INVERSIÓN €148K PARA 2026

Justificación:

- ROI 1453% en Año 1 (cada €1 → €14.53 retorno)
- Mitigación de riesgos críticos inmediatos
- Cumplimiento NIS2 (required en Q2 2026)
- Mejora de IGM de 86% → 90% en 12 meses

Aprobación Recomendada: ☒ SÍ

Responsable: CFO (presupuesto) + CISO (ejecución)

RECOMENDACIÓN 2: PRIORIZAR REMEDIACIÓN CRÍTICA (7 VULNS)

Justificación:

- Riesgo inmediato de explotación
- Plazo corto (7 días)
- Bajo costo (recursos existentes)

Acción: IT Infrastructure + CISO → Completar antes 29 Ene

Aprobación Recomendada: ☒ SÍ (URGENTE)

RECOMENDACIÓN 3: IMPLEMENTAR SCRM PLATFORM EN Q2 2026

Justificación:

- NIS2 compliance requirement (Supply Chain Risk)
- Actualmente: 60% proveedores evaluados (incompleto)
- Plazo: 90 días antes auditoría NIS2
- Budget: €45k (incluido en presupuesto incremental)

Acción: Procurement + Security → RFP antes Feb 15

Aprobación Recomendada: ☒ SÍ

RECOMENDACIÓN 4: ESTABLECER GOVERNANCE CONTINUO

Justificación:

- IGM mejora 12% año-a-año (tendencia positiva)
- Requiere revisión trimestral (board - audit committee)
- Dashboard automatizado para ejecutivos

Acción: CISO → Presentar Q2 (abril), Q3 (julio), Q4 (octubre)

Aprobación Recomendada: ☒ SÍ

RECOMENDACIÓN 5: PLANIFICAR AUDITORÍA EXTERNA NIS2

Justificación:

- NIS2 compliance assessment requerida Q2 2026
- External audit → credibilidad + regulación
- Presupuesto: €50k (ajeno a presupuesto principal)

Acción: CISO + Legal → Seleccionar auditor antes marzo

Aprobación Recomendada: ☒ SÍ

VOTACIÓN PROPUESTA:

- Recomendación 1 (€148k): Votos a favor? _____
- Recomendación 2 (URGENTE): Votos a favor? _____
- Recomendación 3 (SCRM): Votos a favor? _____
- Recomendación 4 (Governance): Votos a favor? _____
- Recomendación 5 (Auditoría): Votos a favor? _____

DIAPPOSITIVA 14: METROLOGÍA Y REPORTING CONTINUO

Contenido

ESTRUCTURA DE REPORTING Y GOVERNANCE CIBERSEGURIDAD	
REPORTING FREQUENCY:	
DIARIA (SOC Dashboard - Security Operations Center)	
- Incidents abiertos - Alertas SIEM top 10 - Vulnerabilidades críticas aún abiertas - MTTD/MTTR promedio (últimas 24h)	
SEMANAL (Security Team - Internal reporting)	
- IGM by module (cambios significativos) - Vulnerabilidades remediadas vs backlog - Indicadores PRAGMATIC (cambios trending) - Phishing campaign results (si aplica)	
MENSUAL (CISO Report - C-Suite)	
- IGM global (tendencia 3 meses) - KPIs principales (MTTD, MFA, vulns críticas) - Riesgos críticos (escalación si requerida) - Presupuesto vs proyección - Roadmap progreso (% completación)	
TRIMESTRAL (Board/Audit Committee - Esta presentación)	
- IGM detallado por módulo CIS - ROI actualizado - Benchmarking vs industria - Hallazgos críticos + remediation plan - Cumplimiento regulatorio (NIS2, GDPR, ENS) - Presupuesto: actual vs proyectado vs beneficios - Recomendaciones para siguientes 3 meses - Q&A + decisiones board	
ANUAL (External Audit - Compliance verification)	
- Auditoría ISMS (ISO 27001) si certificado - Auditoría NIS2 (obligatoria para operadores esenciales) - GDPR Data Protection Impact Assessment (si requerida) - Validación independiente de métricas	
PLATAFORMA TÉCNICA DE REPORTING:	
- Herramienta: Dashboard automatizado (Power BI / Tableau) - Fuentes: SIEM, Scanner vulnerabilidades, IAM, Incident Mgmt - Actualización: Automática diaria - Acceso: Escalonado (SOC team → CISO → Board según nivel) - Alertas: Automáticas cuando IGM baja >5% o riesgos críticos	

DIAPPOSITIVA 15: CIERRE Y PREGUNTAS

Contenido

CIERRE & Q&A	
PUNTOS CLAVE (para llevar):	
1. Posición de seguridad FUERTE y EN MEJORA	
└ IGM: 86% (cuartil superior vs sector)	
└ ROI: 768% en 3 años (inversión muy rentable)	
└ Tendencia: +12% en últimos 12 meses	
2. CUATRO RIESGOS REQUIEREN ACCIÓN (pero manejables)	
└ Crítico: 7 vulnerabilidades sin parchear (7 días plazo)	
└ Altos: SIEM tuning, SCRM completitud, phishing awareness	
└ Presupuesto: €148k; ROI: 1453% en Año 1	
3. PLAN CLARO Y EJECUTABLE (6 meses roadmap)	
└ Hitos bien definidos (mensual)	
└ Responsabilidades claras	
└ Budget presupuestado y aprobable	
4. CUMPLIMIENTO REGULATORIO EN TRACK (NIS2, GDPR, ENS)	
└ Alineación con Directiva NIS2 (Feb 2026 deadline)	
└ GDPR compliance: sin brechas identificadas este año	
└ ENS (español): Categoría III ready para auditoría	
PRÓXIMOS PASOS INMEDIATOS:	
✓ Board aprueba inversión €148k (Esta semana)	
✓ IT remedia 7 vulnerabilidades (Antes 29 Enero)	
✓ CISO inicia RFP para SCRM Platform (Antes 15 Febrero)	
✓ Reporting automatizado en tablero ejecutivo (Enero 2026)	
✓ Audit externo NIS2 scheduled (Mayo-Junio 2026)	
CONTACTOS Y RESPONSABLES:	
CISO:	[Nombre] - ciso@org
Security Operations Head:	[Nombre] - secops@org
IT Infrastructure Manager:	[Nombre] - itmgr@org
Compliance Officer:	[Nombre] - compliance@org
GRACIAS POR SU ATENCIÓN	
¿Preguntas, observaciones, sugerencias?	

NOTAS PARA PRESENTADOR

Guía de Presentación

DURACIÓN TOTAL: 25 minutos (15 diapositivas principales)

TIMING RECOMENDADO:

- Diap 1-2: Portada & Agenda (1 minuto)
- Diap 3: Estado Ejecutivo (2 minutos - LEAD)
- Diap 4: KPI Dashboard (3 minutos - CLAVE)
- Diap 5: IGM por Módulo (3 minutos - DETALLE)
- Diap 6-8: Análisis específicos (5 minutos)
- Diap 9: Benchmarking (2 minutos)
- Diap 10: Hallazgos críticos (3 minutos)
- Diap 11: Roadmap (2 minutos)
- Diap 12: Presupuesto & ROI (3 minutos - CRÍTICO)
- Diap 13: Recomendaciones (2 minutos - VOTACIÓN)
- Diap 14-15: Governance & Q&A (2 minutos)
- Q&A: 5 minutos

TONO RECOMENDADO:

- Confiante (datos respaldados)
- Transparente (riesgos claramente comunicados)
- Orientado a acción (soluciones vs problemas)
- Data-driven (toda afirmación con métrica)

ÉNFASIS EN:

- Diap 3 (Estado): "Buena posición, requiere acciones específicas"
- Diap 4 (KPIs): "IGM 86%, ROI 768% → aprobación likely"
- Diap 10 (Riesgos): "Crítico #1 es manejable en 7 días"
- Diap 12 (Presupuesto): "€148k → €6.99M en 3 años"
- Diap 13 (Recomendaciones): Pedir votación explícita

RESPUESTAS ANTE PREGUNTAS TÍPICAS:

- "¿Cuál es el costo de una brecha?"
Respuesta: "€1-15M según severidad; nuestra inversión es seguro"
- "¿Por qué aún hay 7 vulnerabilidades críticas?"
Respuesta: "Downtime planificado limitaba patching; plan acelerado Q1"
- "¿Cómo comparamos con la industria?"
Respuesta: "Cuartil superior (86% vs 78%); pero MTTD tiene gap"
- "¿Qué pasa si no aprobamos presupuesto?"
Respuesta: "Riesgo CRÍTICO crece; cumplimiento NIS2 en riesgo"

Documento Versión 1.0 | Enero 2026 | España

DESCARGAR: CIS_Controls_Executive_Report_Q1_2026.pptx (Plantilla PowerPoint lista para personalizar)